



Overview



PENETRATION TEST REPORT

for

MEGAQUAGGA PUBLISHING



MQP

Version 1.0 (7/31/2025)

Prepared by **Chibuike Ojukwu**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

EXECUTIVE SUMMARY

This security review was performed to identify weaknesses that could put the MegaQuagga web platform at risk. The assessment revealed several critical issues, the most serious being that the system is running outdated software, which significantly increases its exposure to known threats. We also found that the system was not properly hardened, leaving certain services open to misuse by unauthorized individuals. These vulnerabilities could allow attackers to gain control of the server, disrupt services, or access sensitive data without permission.

To reduce this risk, we recommend immediately updating all outdated software, including the core website system and any associated tools. It's also important to remove any unnecessary features or access points that are not being used, as they create avoidable openings for attackers. Implementing stronger access controls, such as limiting who can log in and from where, will further strengthen the system. Regular monitoring for unusual activity and routine security checks should also become standard practice going forward. These actions will greatly lower the chance of a security incident and improve overall system resilience.



Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

This engagement focused on an internal penetration test of MegaQuagga's local environment. The primary target was a WordPress-based web application hosted at www.megaquagga.local, along with its supporting services and network infrastructure. The assessment aimed to identify vulnerabilities that could be exploited by an attacker with internal access.

The test included host discovery, service enumeration, vulnerability scanning, and exploitation attempts, all within a contained lab network. No denial-of-service testing or attacks against third-party services were conducted. All activities followed ethical guidelines and were approved within the engagement boundaries. The findings are based solely on the assets and IPs explicitly within scope for this assignment.

Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

The assessment was conducted within the bounds of a predefined test environment provided by TripleTen through CloudShare. The authorized target network was the internal Class C subnet 192.168.100.0/24. Testing was permitted only on systems and services within this range. No credentials were pre-supplied, and no destructive techniques (e.g., brute-force, DoS) were used. The assessment focused on identifying exploitable vulnerabilities and demonstrating potential post-exploitation outcomes.

Information Gathering (Reconnaissance):

An initial ping sweep (for i in $\{1..254\}$; `do ping -c 1 192.168.100.$i ...`) was used to identify live hosts. ARP scans revealed multiple responsive IPs, including 192.168.100.1, 192.168.100.2, and 192.168.100.254. DNS resolution confirmed that `www.megaquagga.local` pointed to the internal web server. This host appeared to run a WordPress CMS, making it a priority target for enumeration.

Scanning:

A combination of `nmap` and `wpscan` was used to gather actionable intelligence.

- **Nmap Results:** Detected open ports including 22 (SSH), 80 (HTTP), 443 (HTTPS), 8080, 3389, and others.
- **WPScan Results:** Identified an **outdated WordPress core version**, a vulnerable plugin (`wp_file_manager`), and accessible files such as `readme.html` and `debug.log`. The plugin was known to allow unauthenticated remote file upload, leading to RCE.

This confirmed a viable attack vector.

Exploitation:

Using Metasploit's `exploit/unix/webapp/wp_admin_shell_upload` module, a payload was generated and uploaded to the vulnerable plugin directory. Upon successful upload and execution, a **reverse TCP shell** was established. This shell was upgraded to a **Meterpreter session** to enable more stable, covert post-exploitation activities.

The shell landed under the `www-data` user with limited permissions, a common web service account. Command outputs (`whoami`, `sysinfo`, `ps`) confirmed the environment was Linux-based, and Meterpreter provided additional tooling for enumeration.

Post-Exploitation:

After access was gained, the following actions were taken:

- Verified shell stability and upgraded to Meterpreter
- Ran `sysinfo`, `getuid`, and `ps` to identify OS version, user context, and running processes
- Identified possible local escalation paths (kernel version fingerprinting and file permissions)
- Conducted basic enumeration of `/var/www/html/` for credentials, backups, or exposed configs
- Confirmed no direct root access was obtained but lateral or vertical movement opportunities existed
- Demonstrated stealth by avoiding heavy privilege escalation tooling (e.g., `hashdump`, `getsystem`), using `Stdapi` commands for low forensic footprint.

Reporting:

Following the exploitation and post-exploitation phases, a detailed penetration testing report was compiled to document the findings, actions taken, evidence collected, and security recommendations. All steps were recorded to ensure full transparency and to support reproducibility of results.

The report structure includes a high-level executive summary, a defined scope of engagement, methodology followed, confirmed vulnerabilities with CVEs and CVSS scores, and screenshots for validation. Clear, actionable recommendations are also provided to assist the organization in addressing the identified risks and improving overall security posture. This documentation was prepared with both technical and non-technical stakeholders in mind.



Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

Vulnerability	Outdated WordPress Core Version
CVE	CVE-2019-17671 , CVE-2020-28032
Severity	Medium (CVSS SCORE: 6.8)
OWASP Top 10	A06 (Vulnerable and outdated components)
Risk	Publicly available exploits exist
Steps to exploit	1. WPScan identified WordPress 5.3 (released in 2019) with known RCE and XSS vulnerabilities. 2. wp-file-upload plugin (v4.12.2) found to be vulnerable to unauthenticated file upload 3. Used Metasploit's exploit/unix/webapp/wp_admin_shell_upload module to deliver reverse shell payload. 4. Gained reverse shell access and escalated to Meterpreter for post-exploitation.
Evidence	<pre>(analyst@kali)~ \$ wpscan --url http://www.megaquagga.local _ _ _ _ _ \\ // _\\/_ \\ / / / _) (_ _ _ _ _ ® \\ \\ \\ / _/__\\/_/_/ _' '_ \\ \\ / / / _ _) ((</pre>

V V | | |____/ _\|__| | |
WordPress Security Scanner by the WPScan Team
Version 3.8.27
Sponsored by Automattic - <https://automattic.com/>
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[i] It seems like you have not updated the database for some time.
[?] Do you want to update now? [Y]es [N]o, default: [N]N
[+] URL: <http://www.megaquagga.local/> [192.168.100.2]
[+] Started: Tue Jul 29 20:57:00 2025
Interesting Finding(s):
[+] Headers
| Interesting Entries:
| - Server: Apache/2.4.38 (Debian)
| - X-Powered-By: PHP/7.1.33
| Found By: Headers (Passive Detection)
| Confidence: 100%
[+] robots.txt found: <http://www.megaquagga.local/robots.txt>
| Interesting Entries:
| - /wp-admin/
| - /wp-admin/admin-ajax.php
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%
[+] XML-RPC seems to be enabled: <http://www.megaquagga.local/xmlrpc.php>
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
- http://codex.wordpress.org/XML-RPC_Pingback_API
https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
- https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
- https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
-
https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
[+] WordPress readme found: <http://www.megaquagga.local/readme.html>
Found By: Direct Access (Aggressive Detection)
Confidence: 100%
[+] The external WP-Cron seems to be enabled: <http://www.megaquagga.local/wp-cron.php>
Found By: Direct Access (Aggressive Detection)
Confidence: 60%
References:
- <https://www.iplocation.net/defend-wordpress-from-ddos>
- <https://github.com/wpscanteam/wpscan/issues/1299>
[+] WordPress version 5.3 identified (Insecure, released on 2019-11-12).
Found By: Rss Generator (Passive Detection)
- <http://www.megaquagga.local/feed/>,

<generator>https://wordpress.org/?v=5.3</generator>
| - http://www.megaquagga.local/comments/feed/,
<generator>https://wordpress.org/?v=5.3</generator>
[+] WordPress theme in use: twentytwenty
| Location: http://www.megaquagga.local/wp-content/themes/twentytwenty/
| Last Updated: 2024-11-13T00:00:00.000Z
| Readme: http://www.megaquagga.local/wp-content/themes/twentytwenty/readme.txt
| [!] The version is out of date, the latest version is 2.8
| Style URL:
http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0
| Style Name: Twenty Twenty
| Style URI: https://wordpress.org/themes/twentytwenty/
| Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor...
| Author: the WordPress team
| Author URI: https://wordpress.org/
|
| Found By: Css Style In Homepage (Passive Detection)
| Confirmed By: Css Style In 404 Page (Passive Detection)
|
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0,
Match: 'Version: 1.0'
[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)
[i] Plugin(s) Identified:
[+] social-warfare
| Location: http://www.megaquagga.local/wp-content/plugins/social-warfare/
| Last Updated: 2024-09-17T20:18:00.000Z
| [!] The version is out of date, the latest version is 4.5.4
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By:
| Urls In 404 Page (Passive Detection)
| Comment (Passive Detection)
|
| Version: 3.5.2 (100% confidence)
| Found By: Comment (Passive Detection)
| - http://www.megaquagga.local/, Match: 'Social Warfare v3.5.2'
| Confirmed By:
Query Parameter (Passive Detection)
http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2
-

http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2

| Readme - Stable Tag (Aggressive Detection)

| - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt

| Readme - ChangeLog Section (Aggressive Detection)

| - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt

[+] wp-advanced-search

| Location: http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/

| Last Updated: 2024-11-05T18:15:00.000Z

| [!] The version is out of date, the latest version is 3.3.9.3

|

| Found By: Urls In Homepage (Passive Detection)

| Confirmed By: Urls In 404 Page (Passive Detection)

|

| Version: 3.3.3 (80% confidence)

| Found By: Readme - Stable Tag (Aggressive Detection)

| - http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/readme.txt

[+] wp-file-upload

| Location: http://www.megaquagga.local/wp-content/plugins/wp-file-upload/

| Last Updated: 2025-01-07T07:54:00.000Z

| [!] The version is out of date, the latest version is 4.25.1

|

| Found By: Urls In Homepage (Passive Detection)

| Confirmed By: Urls In 404 Page (Passive Detection)

|

| Version: 4.12.2 (50% confidence)

| Found By: Readme - ChangeLog Section (Aggressive Detection)

| - http://www.megaquagga.local/wp-content/plugins/wp-file-upload/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)

Checking Config Backups - Time: 00:00:01

<===== (137 /

137) 100.00% Time: 00:00:01

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.

[!] You can get a free API token with 25 daily requests by registering at

https://wpscan.com/register

[+] Finished: Tue Jul 29 20:57:07 2025

[+] Requests Done: 176

[+] Cached Requests: 7

[+] Data Sent: 61.226 KB

[+] Data Received: 549.099 KB

[+] Memory used: 335.613 MB

[+] Elapsed time: 00:00:07

	Found By: Headers (Passive Detection) Confidence: 100% [+] robots.txt found: http://www.megaquagga.local/robots.txt Interesting Entries: - /wp-admin/ - /wp-admin/admin-ajax.php Found By: Robots Txt (Aggressive Detection) Confidence: 100% [+] XML-RPC seems to be enabled: http://www.megaquagga.local/xmlrpc.php Found By: Direct Access (Aggressive Detection) Confidence: 100% References: - http://codex.wordpress.org/XML-RPC_Pingback_API - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/ - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/ - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/ - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/ [+] WordPress readme found: http://www.megaquagga.local/readme.html Found By: Direct Access (Aggressive Detection) Confidence: 100% [+] The external WP-Cron seems to be enabled: http://www.megaquagga.local/wp-cron.php Found By: Direct Access (Aggressive Detection) Confidence: 60% References: - https://www.iplocation.net/defend-wordpress-from-ddos - https://github.com/wpscanteam/wpscan/issues/1299 [+] WordPress version 5.3 identified (Insecure, released on 2019-11-12). Found By: Rss Generator (Passive Detection) - http://www.megaquagga.local/feed/, <generator>https://wordpress.org/?v=5.3</generator> - http://www.megaquagga.local/comments/feed/, <generator>https://wordpress.org/?v=5.3</generator> [+] WordPress theme in use: twentytwenty Location: http://www.megaquagga.local/wp-content/themes/twentytwenty/ Last Updated: 2024-11-13T00:00:00.000Z Readme: http://www.megaquagga.local/wp-content/themes/twentytwenty/readme.txt [!] The version is out of date, the latest version is 2.8 Style URL: http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0 Style Name: Twenty Twenty Style URI: https://wordpress.org/themes/twentytwenty/ Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor... Author: the WordPress team
--	--

	Author URI: https://wordpress.org/ Found By: Css Style In Homepage (Passive Detection) Confirmed By: Css Style In 404 Page (Passive Detection) Version: 1.0 (80% confidence) Found By: Style (Passive Detection) - http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0, Match: 'Version: 1.0' [+] Enumerating All Plugins (via Passive Methods) [+] Checking Plugin Versions (via Passive and Aggressive Methods) [i] Plugin(s) Identified: [+] social-warfare Location: http://www.megaquagga.local/wp-content/plugins/social-warfare/ Last Updated: 2024-09-17T20:18:00.000Z [!] The version is out of date, the latest version is 4.5.4 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection) Comment (Passive Detection) Version: 3.5.2 (100% confidence) Found By: Comment (Passive Detection) - http://www.megaquagga.local/, Match: 'Social Warfare v3.5.2' Confirmed By: Query Parameter (Passive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2 - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2 Readme - Stable Tag (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt Readme - ChangeLog Section (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt [+] wp-advanced-search Location: http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/ Last Updated: 2024-11-05T18:15:00.000Z [!] The version is out of date, the latest version is 3.3.9.3 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection) Version: 3.3.3 (80% confidence)
--	---

	Found By: Readme - Stable Tag (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/readme.txt [+] wp-file-upload Location: http://www.megaquagga.local/wp-content/plugins/wp-file-upload/ Last Updated: 2025-01-07T07:54:00.000Z [!] The version is out of date, the latest version is 4.25.1 Found By: Urls In Homepage (Passive Detection) Confirmed By: Urls In 404 Page (Passive Detection) Version: 4.12.2 (50% confidence) Found By: Readme - ChangeLog Section (Aggressive Detection) - http://www.megaquagga.local/wp-content/plugins/wp-file-upload/readme.txt [+] Enumerating Config Backups (via Passive and Aggressive Methods) Checking Config Backups - Time: 00:00:01 <===== (137 / 137) 100.00% Time: 00:00:01 [i] No Config Backups Found. [!] No WPScan API Token given, as a result vulnerability data has not been output. [!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register [+] Finished: Tue Jul 29 20:57:07 2025 [+] Requests Done: 176 [+] Cached Requests: 7 [+] Data Sent: 61.226 KB [+] Data Received: 549.099 KB [+] Memory used: 335.613 MB [+] Elapsed time: 00:00:07
--	--

Vulnerability	Exposed XML-RPC Endpoint
CVE	Not applicable (misconfiguration)
Severity	Medium (CVSS SCORE: 5.3)
OWASP Top 10	A05 (Security Misconfiguration)
Risk	Known attack surface, widely abused for brute-force and pingback DDoS
Steps to exploit	1. WPScan detected xmlrpc.php enabled 2. Attempted various POST methods to validate accessibility 3. Endpoint confirmed active; enumeration of possible actions succeeded
Evidence	WPScan XML-RPC detection output HTTP logs showing POST request responses

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Successfully exploited a vulnerable version of WordPress (5.3) with a publicly known remote code execution flaw.
- Used WPScan to detect version details and identify the vulnerable wp-file-upload plugin (v4.12.2).
- Leveraged Metasploit's exploit/unix/webapp/wp_admin_shell_upload module to upload a PHP payload.
- Established a **reverse TCP shell** back to the attack machine and confirmed access.
- Upgraded the shell session to a **Meterpreter implant** to enable deeper system interaction.

POST-EXPLOITATION PHASE

- Verified shell stability and escalated to Meterpreter for extended access.
- Enumerated system info using sysinfo, getuid, and ps to understand user privileges and running processes.
- Extracted key configuration files and browsed web directory contents for sensitive credentials.
- The confirmed user was operating under a low-privilege service account (www-data) and operating in a Linux environment.
- Explored file system and user home directories for indicators of privilege escalation vectors.
- Collected evidence from log files and reconfirmed XML-RPC was exposed for potential DDoS or brute-force vectors.
- Maintained access stealthily and gathered artifacts for reporting and remediation guidance.

Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

Recommendation #1: Update WordPress Core and Plugins

Immediately upgrade WordPress to the latest stable release. Outdated versions (such as 5.3) are known to contain critical remote code execution and XSS vulnerabilities. Additionally, remove or update the vulnerable wp-file-upload plugin to a secure version or replace it with a vetted alternative that follows secure development practices.

Recommendation #2: Disable or Restrict Access to xmlrpc.php

Disable the xmlrpc.php endpoint if it is not required. If application functionality depends on it, implement rate limiting, IP whitelisting, or a Web Application Firewall (WAF) rule to restrict access. Leaving xmlrpc.php exposed introduces risk for brute-force attacks and DDoS-style abuse via pingback functionality.

Recommendation #3: Harden the Server and Review Permissions

Ensure least privilege access is enforced across all user and service accounts. Lock down file and directory permissions to prevent unauthorized uploads or execution. Regularly audit web directories for unauthorized files, and remove any default or test scripts that may expose sensitive information. Additionally, monitor system logs and implement intrusion detection alerts to quickly respond to suspicious activity.



Conclusion

CONCLUSION

The assessment uncovered multiple security risks, including an outdated WordPress core, a vulnerable plugin, and an exposed xmlrpc.php endpoint, all of which could be exploited to gain unauthorized access and control. To address these issues, we recommend updating all outdated components, disabling unnecessary features like XML-RPC, and enforcing stricter access controls and server hardening measures.